Cours 4 — Sécurité de l'information : les critères DICP

« Protéger les données », concrètement, c'est **garantir quatre propriétés** : **Disponibilité, Intégrité, Confidentialité, Preuve** — le **DICP**. Chaque incident de sécurité peut se lire comme l'atteinte à un ou plusieurs de ces critères.

1. Pourquoi des « critères » ?

Pour raisonner sur la sécurité, on ne dit pas « les données sont protégées » (trop vague) : on précise **quelle propriété** est menacée. Cela permet de choisir la **bonne parade**. Les quatre critères sont le vocabulaire de base de toute analyse de risques (Cours 5).

2. D — Disponibilité

Les données et services sont **accessibles quand on en a besoin**.

- **Atteinte** : panne matérielle, attaque par déni de service (DDoS), ransomware qui bloque les fichiers, suppression accidentelle.
- **Parades** : redondance, sauvegardes, plan de reprise, protection anti-DDoS.

3. I — Intégrité

Les données sont **exactes et non altérées** : elles n'ont pas été modifiées de façon non autorisée.

- **Atteinte** : modification d'un IBAN sur un virement, corruption de fichier, falsification d'un enregistrement.
- **Parades** : contrôles d'accès, journalisation, et surtout **fonctions de hachage** (cours « Intégrité et hachage »).

> C'est le pont vers la suite : l'**intégrité** se vérifie techniquement avec le **hachage**, cœur du module cryptographie. Un fichier dont l'empreinte a changé a été altéré.

4. C — Confidentialité

Les données ne sont accessibles qu'aux **personnes autorisées**.

- **Atteinte** : vol d'un ordinateur non chiffré, fuite de documents, interception d'une communication, accès d'un employé non habilité.
- **Parades** : habilitations, chiffrement (cours « Chiffrement symétrique (AES) »), cloisonnement.

5. P — Preuve (traçabilité)

On peut **prouver qui a fait quoi, et quand** : les actions sont **tracées** et **non répudiables**.

- **Atteinte** : logs absents ou effaçables, action impossible à attribuer, décompte d'un vote non auditable.
- **Parades** : journaux d'activité protégés, horodatage, signatures.



DICP ou « CIA » ? Au niveau international, on parle souvent de la triade **CIA** : *Confidentiality, Integrity, Availability*. En France, l'ANSSI et la méthode EBIOS ajoutent la **Preuve** (traçabilité), d'où le **DICP**.

6. Un incident touche souvent PLUSIEURS critères

Les critères ne sont pas exclusifs. Un même incident peut en atteindre plusieurs :

Example 1. Exemple

Un **ransomware** chiffre les fichiers d'un hôpital :

- les fichiers sont inaccessibles → **Disponibilité** ;
- ils sont chiffrés / potentiellement altérés → **Intégrité** ;
- si les attaquants ont exfiltré des données avant de chiffrer → **Confidentialité**.

Savoir **nommer** les critères touchés est la première étape de l'analyse : c'est exactement l'objet du TD de cette séance.

7. Vers l'analyse de risques

Quand un critère est atteint, il se produit un **événement redouté** (ex. : « des données confidentielles sont divulguées »). Le Cours 5 apprendra à **évaluer** ces événements (gravité, vraisemblance) et à les **cartographier**.

8. Mémo

Critère	Question	Atteinte typique
D isponibilité	Accessible quand on en a besoin ?	Panne, DDoS, ransomware
I ntégrité	Exacte et non altérée ?	Modification, corruption
C onfidentialité	Réservée aux autorisés ?	Fuite, vol, interception
P reuve	Peut-on prouver qui a fait quoi ?	Logs absents, action non attribuable